
How to Prevent Active Directory Attacks by Securing Privileged Accounts

Key Takeaways

- Most Active Directory attacks succeed by abusing privileged accounts.
- Domain Admins are high-value targets and must be protected differently
- Privileged identity management reduces standing access and attack paths
- Active Directory security depends on visibility, control, and discipline

Let's be honest—when Active Directory is compromised, the incident is never small.

Almost every major enterprise breach involves Active Directory at some point. Attackers may enter through phishing, malware, or a misconfigured endpoint, but their real goal is always the same: gain control over privileged identities and Domain Admin accounts.

Once that happens, containment becomes difficult and recovery becomes painful.

Preventing Active Directory attacks isn't about adding more tools. It's about securing the identities that hold the keys to the kingdom. This blog breaks down how [Active Directory attacks](#) actually happen, why privileged accounts are the main target, and what best practices truly reduce risk in real environments.

Why Active Directory becomes the center of enterprise attacks

Active Directory sits at the core of identity, authentication, and authorization. It determines who can log in, what they can access, and which systems trust one another. When attackers gain influence here, they inherit that trust by default.

Active Directory controls enterprise-wide trust

[Active Directory](#) acts as the authoritative source for identity across the environment. Every authentication request, group membership, and access decision depends on it.

This means compromising Active Directory doesn't just give access to one system. It gives attackers the ability to impersonate users, create new identities, and redefine trust relationships across the domain. That level of control is far more valuable than accessing a single application or server.

1. Identity-based access amplifies attacker reach

Modern environments rely heavily on identity-based access rather than network boundaries. Once authenticated, users and services can access multiple systems without re-authenticating.

Attackers exploit this design. Instead of attacking systems one by one, they target identities that already have broad access. When a single identity is compromised, attackers can move laterally using legitimate permissions rather than exploits.

This is why Active Directory attacks often feel invisible in the early stages.

2. Privilege sprawl expands the attack surface

Over time, Active Directory environments accumulate excess privilege. Users retain access they no longer need. Service accounts gain permissions for convenience. Administrative roles are assigned permanently.

Each unnecessary permission becomes a potential attack path. An account that was harmless years ago may now have enough access to escalate privileges if compromised. This sprawl is one of the most common weaknesses in Active Directory security.

Attackers don't create these paths — they discover and reuse them.

3. Limited visibility hides early warning signs

Active Directory attacks rarely start with Domain Admin access. They begin with subtle changes: unusual logins, privilege usage outside normal patterns, or unexpected access attempts.

Without strong visibility into identity behavior, these early signals are easy to miss. Actions performed using valid credentials often look legitimate, even when they are part of an attack.

This lack of visibility allows attackers to operate quietly until they reach high-value privileges.

Security Checklist: Hardening
Your Active Directory with
Advanced Strategies

- Statistics and Trends
- Security Checklist
- Advanced Strategies for AD Security

[Download the Whitepaper Now!](#)

Security Checklist

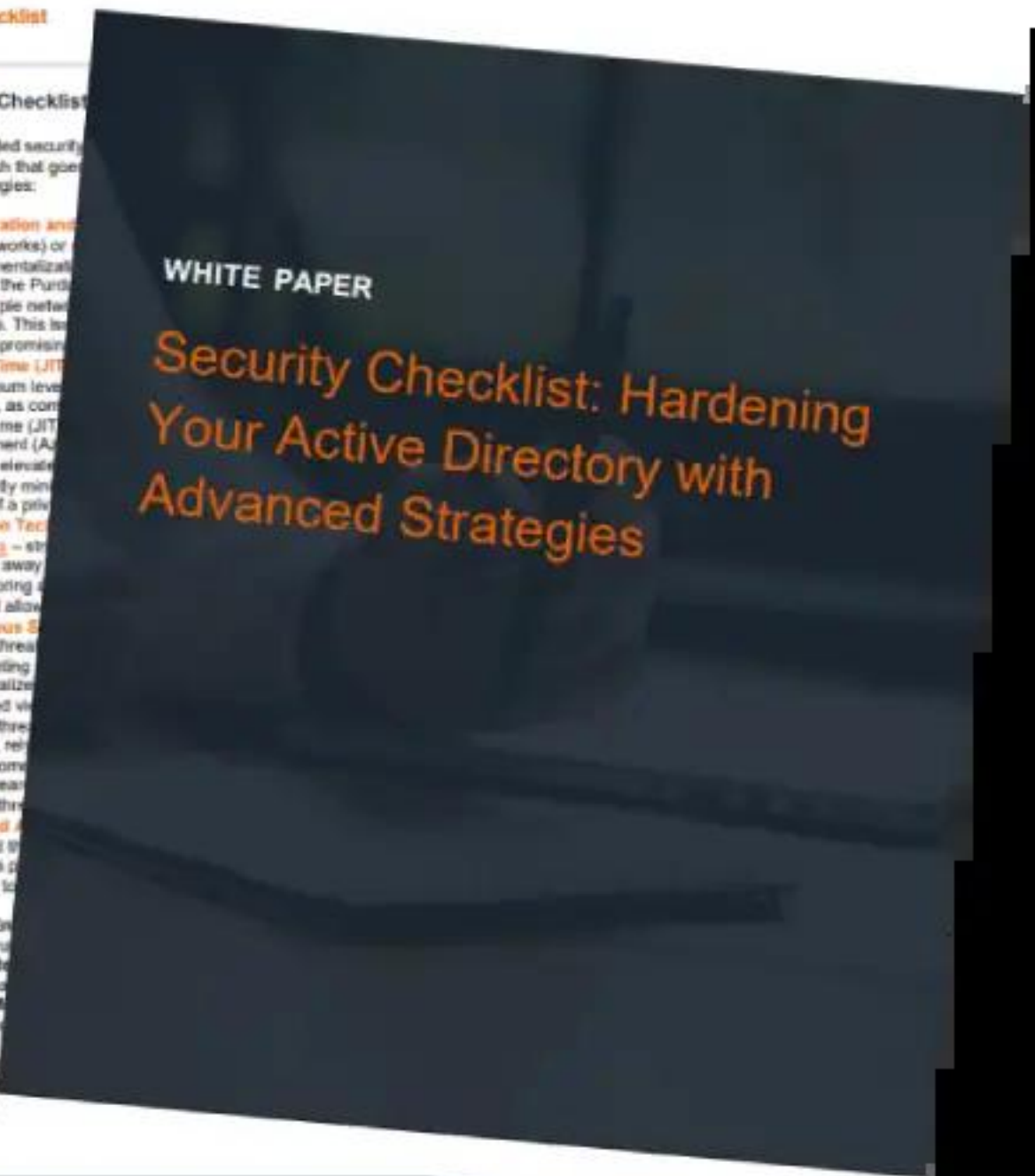
Beyond the Checklist

While the provided security layered approach that goes into these strategies:

- **Segmentation and Area Networks** or compartmentalization. Consider the Purdue with multiple network resources. This is after compromise.
- **Just-In-Time (JIT)** the minimum level accounts, as compared to Just-In-Time (JIT) Management (AJIT). With JIT, elevate significantly minimize damage if a privilege is abused.
- **Deception Technology** – strong attackers away. By monitoring and which will allow.
- **Continuous Security** evolving threat implementing can centralized centralized view potential threat. However, relying hunting come actively search potential threat.
- **Privileged Access** They hold the solution is designed to

- ✓ En
- ✓ Re
- ✓ M

By implementing multi-layered defense, vigilance and ad



WHITE PAPER

Security Checklist: Hardening Your Active Directory with Advanced Strategies

How do attackers abuse privileged identities in Active Directory?

Privileged identities are the most reliable way for attackers to maintain access and expand control.

1. Standing privileges create persistent attack paths

Many organizations assign permanent admin rights “just in case.” These standing privileges become permanent attack paths.

For example, a user who was granted admin rights for a temporary project may retain those privileges for years. If that account is compromised later, attackers inherit elevated access instantly.

This is one of the most common failures in active directory privileged identity management.

2. Service accounts as overlooked attack vectors

Service accounts often run critical applications but are rarely monitored closely. They may use static passwords, lack [MFA](#), and have broad permissions.

Attackers frequently target these accounts because:

- Passwords rarely change
- Permissions are excessive
- Activity looks “normal”

Compromising a service account can quietly lead to [privilege escalation](#) without raising alerts.

3. Domain Admin accounts as the ultimate objective

Domain Admins have unrestricted control over the domain. Attackers aim to reach this level because it allows them to:

- Disable security tools
- Create backdoor accounts
- Modify Group Policies
- Access any system

This is why securing Domain Admins must be treated differently from other accounts.

4, Abuse of delegated permissions and misconfigurations

Active Directory environments often contain complex delegation rules that no one fully understands.

Attackers exploit these misconfigurations to gain privileges indirectly—without ever touching a Domain Admin account until the final stage.

What does strong Active Directory security actually require?

Effective [Active Directory security](#) focuses on reducing privilege, increasing visibility, and limiting blast radius.

1. Least privilege enforced across all roles

Least privilege means users and services only have access required for their current task—nothing more.

For example, helpdesk staff may need password reset capabilities but not access to sensitive group memberships. Enforcing this [reduces lateral movement](#) opportunities.

2. Active directory privileged identity management in practice

Privileged Identity Management (PIM) replaces standing access with time-bound, approved elevation.

Instead of permanent admin rights, users request access when needed. Access is logged, limited, and revoked automatically.

This significantly reduces the window attackers can exploit.

3. Strong authentication for privileged accounts

Privileged accounts should never rely on passwords alone.

Multi-factor authentication, separate admin credentials, and restricted login locations [reduce the risk of credential theft](#) and misuse.

4. Visibility into privileged account behavior

Visibility matters as much as controls. Security teams need to see:

- When privileged access is requested
- Which systems are accessed
- What changes are made

Without visibility, misuse looks like legitimate activity.

How can organizations secure privileged accounts and Domain Admins?

Securing privileged accounts requires deliberate operational discipline, not just policy documents.

1. Separate admin and user identities

Admins should never use the same account for daily work and privileged tasks.

A compromised user account should not automatically lead to administrative access. Separation creates a barrier attackers must overcome.

2. Restrict Domain Admin usage

Domain Admin accounts should be used rarely and only for domain-level tasks.

For example, routine server administration should not require Domain Admin rights. Reducing usage reduces exposure.

3. Monitor and audit privileged access continuously

Every privileged action should be logged and reviewed.

Unusual patterns—such as access at odd hours or from unfamiliar systems—should trigger investigation.

4. Protect privileged accounts at the endpoint level

Endpoints used by admins should be hardened and monitored closely.

If an attacker compromises an admin's endpoint, they gain a direct path to privileged credentials. Endpoint security must be part of Active Directory attack prevention.

How does this prevent Active Directory attacks in real life?

These practices disrupt the attacker's playbook at multiple stages.

- **Breaking the privilege escalation chain**
When standing privileges are removed and elevation is controlled, attackers struggle to move upward even after initial access.
- **Reducing lateral movement opportunities**
Limited permissions and monitored access prevent attackers from moving freely across systems.
- **Increasing detection before domain compromise**
Visibility into privileged behavior helps teams detect misuse early—before Domain Admin access is achieved.
- **Containing damage when incidents occur**
Even if an account is compromised, reduced privileges and segmented access limit the blast radius.

How Fidelis Security helps you achieve stronger Active Directory protection

[Fidelis Security](#) approaches Active Directory security from a practical angle. Instead of assuming attacks are obvious or noisy, it focuses on how identity-based attacks actually play out in real enterprise environments, particularly those aimed at privileged accounts and Domain Admins.

- **Spotting Active Directory attacks early, before they spiral**
Most AD attacks don't start with something dramatic. They begin with small, easy-to-miss signs—an odd authentication pattern, a privilege used in an unusual way, a directory action that doesn't quite fit. [Fidelis helps bring these early signals into view](#), so teams can intervene while the attack is still manageable, rather than discovering it after damage has already spread.
- **Making privileged account misuse easier to recognise**
In day-to-day operations, privileged accounts are busy. That makes misuse hard to spot. Fidelis gives teams clearer visibility into how Domain Admins and other high-privilege identities are actually being used, making it easier to tell the difference between routine administrative work and activity that suggests credentials are being abused or privileges are being pushed too far.
- **Breaking attacker movement inside the domain**
Attackers rely on blending in. They move laterally using the same tools and permissions administrators use every day. By [combining Active Directory-aware monitoring with deception](#) techniques, Fidelis helps surface activity that would otherwise pass as normal, allowing teams to interrupt lateral movement and persistence before control of the

domain is established.

- **Helping SOC teams respond with confidence, not guesswork**

When an AD incident unfolds, uncertainty slows everything down. Fidelis connects Active Directory signals with network and endpoint context, giving analysts a clearer picture of where the activity began, which identities are involved, and which systems are affected. That clarity makes response faster and, just as importantly, more confident during high-pressure situations.

Multi-Layered AD Defense – Fidelis Active Directory Intercept

- Defeat AD Attacks
- AD-aware Network Traffic Analysis
- Integrated Intelligent Deception

[Download Datasheet](#)

Datasheet

Fidelis



Multi-layered Defense

Active Directory (AD) is the enterprise's management. It authenticates and authorizes, provides for the storage and deployment of services such as management, and more. launch point from which to escalate privileges, and execution, data exfiltration.

Protecting AD is a prime target. But many tools fall short in imminent attack. And or game over. They can't network traffic and data protection tools.

That's where Fidelis Active Directory Intercept comes in.

See More. Stop Only with Active Directory Intercept

Fidelis Active Directory Intercept technology with four just identify AD threat. Intercept gives you exactly how, where, into your network, and ability to defend against.

Fidelis Active Directory Intercept™

Multi-Layered Active Directory Defense

For advanced protection, integrating [Fidelis Active Directory Intercept](#) provides enhanced visibility, swift threat response, and proactive defenses like intelligent deception and real-time monitoring. Together, these tools create a layered security strategy that not only protects your organization but also strengthens trust and compliance.

Investing in these solutions now is key to staying ahead of evolving threats and safeguarding your digital ecosystem effectively.